Bloque 2: Ecosistema OWASP y Protección Proactiva

FADENA

OWASP y Protección Proactiva

Ing. Roxana Quiroga Sollinger

Protección Proactiva Parte2

Módulo 3: OWASP y Protección Proactiva

FADENA

3.1 OWASP

3.2 OWASP TOP 10

3.3 Protección Proactiva

3.4 Defensa en Profundidad



3.3 Protección Proactiva

Modelo OWASP SAMM

Estructura

https://owaspsamm.org/

SAMM significa Software Assurance Maturity Model (Modelo de Madurez de Aseguramiento de Software). Es marco abierto, prescriptivo y medible para la seguridad del software.

Prescriptivo y Abierto

Es un marco totalmente definido, accesible y simple de aplicar, estructurado de forma comprensible incluso para personal no especializado en ciberseguridad.

Iterativo y Medible

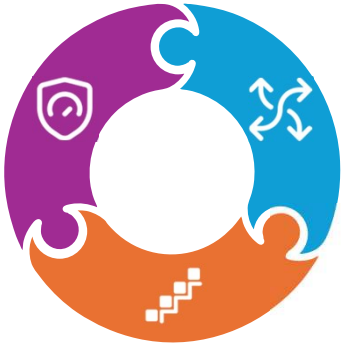
Facilita la evaluación de las prácticas actuales, permitiendo construir programas de seguridad por etapas con mejoras progresivas y actividades medibles.

Flexible y Adaptable

Diseñado para adaptarse con facilidad a empresas pequeñas, medianas y grandes, sin importar la metodología de desarrollo que utilicen.

Medible

Niveles de madurez definidos en todas las prácticas de seguridad.



Versátil

Agnóstico de tecnología, procesos y organización.

Accionable

Caminos claros para mejorar los niveles de madurez.

3.3 Protección Proactiva

Modelo OWASP SAMM

Madurez a la Medida de la Empresa

SAMM no exige alcanzar el nivel máximo de madurez en todas las categorías. Ofrece la libertad de adaptar el modelo a las necesidades reales.

Cada organización puede definir sus objetivos específicos para cada Práctica de Seguridad según su perfil de riesgo y contexto particular.

Comprensión Universal

Las soluciones y actividades son claras y fáciles de seguir para equipos técnicos y no técnicos.

Ubicación en la Ruta (Roadmap)

Ofrece un diagnóstico preciso sobre en qué punto se encuentra la organización dentro de su implementación de la seguridad.

Paso al Siguiente Nivel

Recomienda acciones concretas e hitos claros para avanzar al siguiente nivel de madurez.

Demostración de Valor

Facilita mostrar progresos constantes y justificar actividades de seguridad mediante mediciones objetivas.

3.3 Protección Proactiva

Modelo OWASP SAMM

Estructura

Negocio

5 Funciones de Negocio con categorías principales de actividades que cualquier organización dedicada al desarrollo de software debe llevar a cabo.

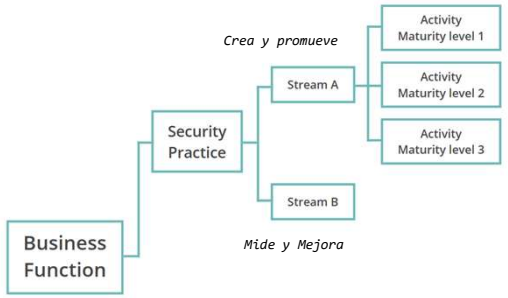
Prácticas de Seguridad

15 Prácticas de Seguridad que son áreas operativas específicas (3 por cada función) que generan garantías integrales en el ciclo de vida del software.

Nivel de Madurez

3 Niveles de Madurez con una ruta (roadmap) progresiva de implementación con actividades estructuradas, desde prácticas básicas hasta métricas sofisticadas.

01 02 03



Función de Negocio (Business Function)
Nivel superior que agrupa categorías clave de desarrollo.

Prácticas de Seguridad (Security Practice):
3 áreas por función encargadas de generar garantías específicas.

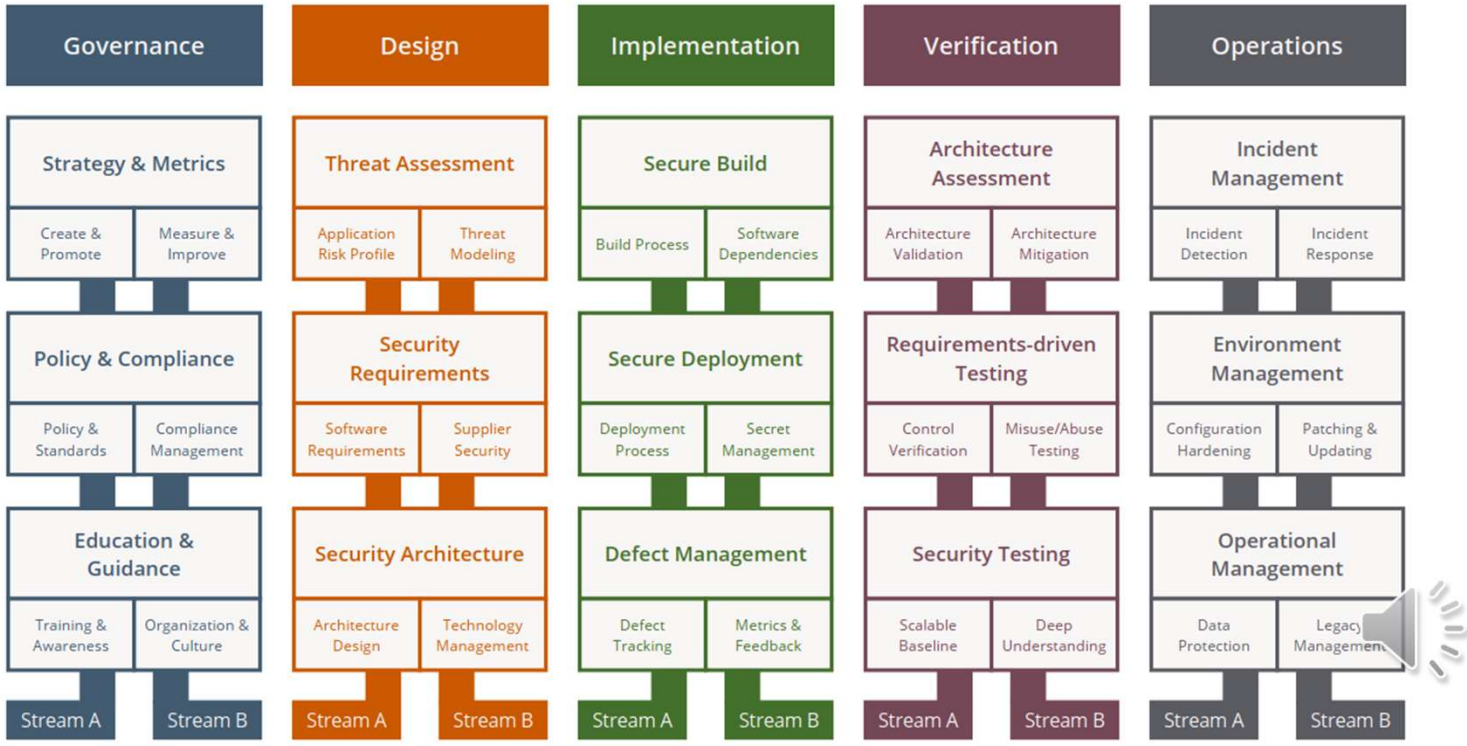
Vertientes (Stream A & B)
Dividen cada práctica en dos flujos lógicos con objetivos particulares.

Niveles de Madurez (Maturity Levels 1-3)
Dividen cada práctica en dos flujos lógicos con objetivos particulares.

FADENA

3.3 Protección Proactiva

Modelo OWASP SAMM



FADENA

3.3 Protección Proactiva

Modelo OWASP SAMM

Funciones de Negocio

Gobierno

La gobernanza se centra en los procesos y actividades relacionados con la forma en que una organización gestiona las actividades generales de desarrollo de software.

Diseño

El diseño abarca los procesos y actividades relacionados con la forma en que una organización define objetivos y crea software en el marco de proyectos de desarrollo.

Implementación

La implementación se centra en los procesos y actividades relacionados con la forma en que una organización construye y despliega componentes de software, así como en los defectos asociados a ellos.



Operaciones

La función empresarial de Operaciones abarca las actividades necesarias para garantizar que se mantengan la confidencialidad, la integridad y la disponibilidad a lo largo de la vida operativa de una aplicación y de los datos asociados a ella.

Verificación

La verificación se centra en los procesos y actividades relacionados con la forma en que una organización examina y prueba los artefactos generados a lo largo del desarrollo de software.

3.3 Protección Proactiva

Modelo OWASP SAMM

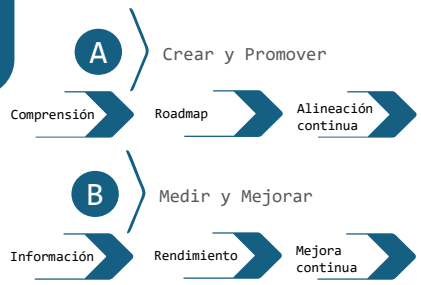
Prácticas de Seguridad

Gobierno

Estrategia y Métricas (SM)

Evita que los esfuerzos de seguridad del software resulten descoordinados o contraproducentes al estructurarlos dentro de un plan integral y eficiente.

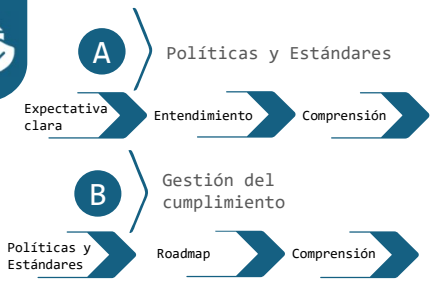
- Alinear objetivos con los de la organización.
- Difundir continuamente el programa de seguridad.
- Medición continua.



Políticas y Cumplimiento (PC)

Alinea los estándares internos y las regulaciones externas con los objetivos del negocio, integrando la verificación en el ciclo de desarrollo de software.

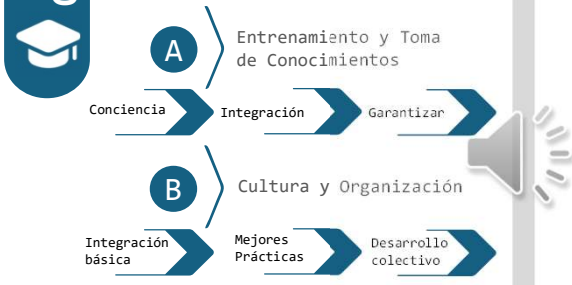
- Traduce normas legales y obligaciones en requisitos.
- Establec puntos de verificación.
- Fomenta el cmplimiento normativo.



Educación y Orientación (EG)

Capacita al personal involucrado en el ciclo de vida del software con conocimientos y recursos para identificar y mitigar riesgos de seguridad de forma proactiva.

- Implementa programas de formación y concientiza.
- Mejora la cultura organizacional.
- Proporciona los recursos para crear software seguro.



3.3 Protección Proactiva

Modelo OWASP SAMM

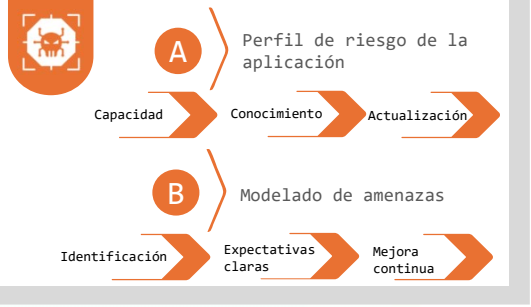
Prácticas de Seguridad

Diseño

Evaluación de Amenazas (TA)

Identifica y comprende los riesgos a nivel de proyecto en función de la funcionalidad del software y su entorno de ejecución.

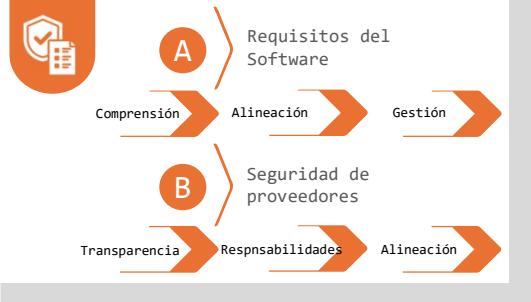
- Prioriza las iniciativas de seguridad y las fundamenta.
- Evoluciona al modelo incluyendo riesgos e impactando downstream.
- Monitorear de forma continua el desempeño de la organización frente a las amenazas.



Requisitos de Seguridad (SR)

Establece los criterios necesarios para proteger la aplicación y estructurar las exigencias de desarrollo seguro para proveedores externos.

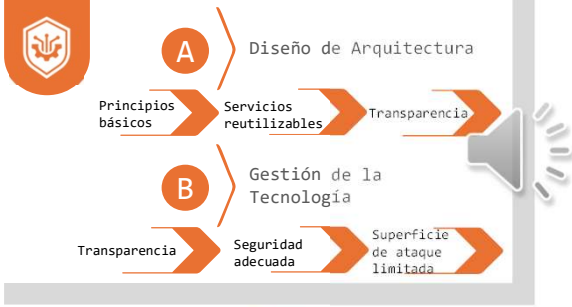
- Define los objetivos y expectativas para resguardar los datos y servicios centrales.
- Estandariza los requisitos de seguridad aplicados a terceros y al desarrollo subcontratado.
- Excluye la gestión librería técnicas de terceros.



Arquitectura de Seguridad (SA)

Se enfoca en la seguridad de los componentes y las tecnologías utilizadas durante el diseño arquitectónico del software.

- Evalúa la selección y composición de los componentes fundamentales de la solución.
- Garantiza la seguridad de las tecnologías de soporte a lo largo de las etapas de desarrollo, despliegue y operación.



3.3 Protección Proactiva

Modelo OWASP SAMM

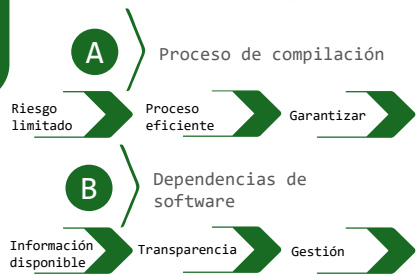
Prácticas de Seguridad

Implementación

Construcción Segura (SB)

Promueve el desarrollo de software de forma estandarizada, reproducible y confiable mediante procesos automatizados y el uso de componentes seguros.

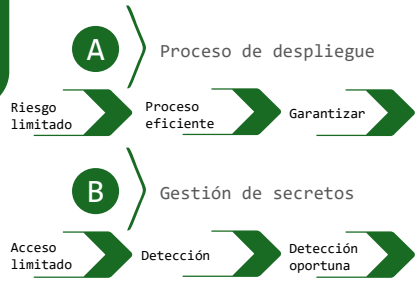
- Elimina la subjetividad del flujo de construcción al integrar pruebas automáticas.
- Identifica y monitorea continuamente la seguridad.
- Aplica sobre las dependencias externas controles y comprobaciones de seguridad.



Despliegue Seguro (SD)

Garantiza la seguridad e integridad de las aplicaciones durante su entrega a entornos de producción.

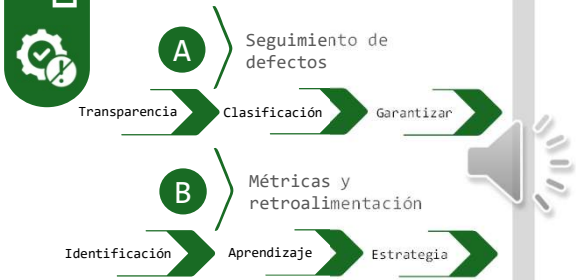
- Minimiza errores manuales automatizando el despliegue.
- Protege credenciales, tokens y contraseñas trasladándolos hacia bóvedas.
- Genera secretos de forma dinámica durante la fase de despliegue.



Gestión de Defectos (DM)

Se enfoca en recopilar, registrar y analizar las fallas de seguridad del software para respaldar la toma de decisiones basada en métricas.

- Administra y resuelve los defectos (SLA).
- Enriquece la información de las vulnerabilidades para generar métricas .
- Estrategia general de seguridad.



3.3 Protección Proactiva

Modelo OWASP SAMM

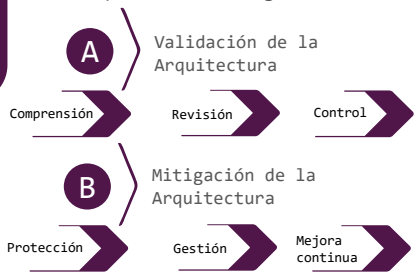
Prácticas de Seguridad

Verificación

Evaluación de Arquitectura (AA)

Garantiza que la arquitectura de la aplicación e infraestructura cumpla con los requisitos de seguridad, mitigando las amenazas identificadas.

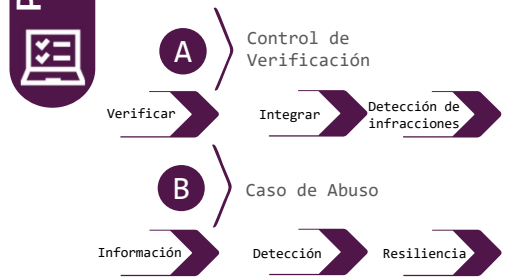
- Comprueba el cumplimiento de forma progresiva.
- Revisa el diseño arquitectónico frente a amenazas típicas y las encontradas en la evaluación de amenazas.
- Retroalimenta a la práctica de Arquitectura de Seguridad



Pruebas basadas en requisitos (RT)

Verifica que los controles de seguridad implementados funcionen según lo previsto y cumplan con las especificaciones definidas para el proyecto.

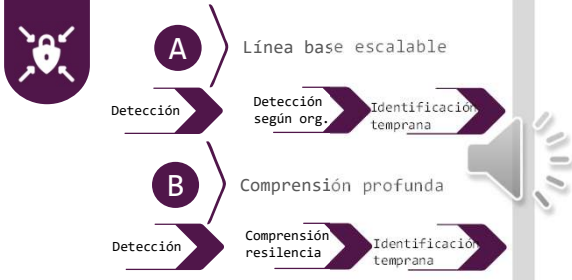
- Valida el correcto funcionamiento de los controles requeridos y detecta fallos.
- Evoluciona hacia la automatización de pruebas.
- Se enfoca en confirmar el cumplimiento de requisitos.



Test de Seguridad (ST)

Combina automatización escalable para fallos comunes con análisis manual experto para identificar vulnerabilidades complejas y de lógica de negocio.

- Establece una línea base automatizada para detectar problemas básicos.
- Libera tiempo para que especialistas evalúen vectores de ataque complejos.
- Se centran en debilidades técnicas e inconsistencias.



3.3 Protección Proactiva

Modelo OWASP SAMM

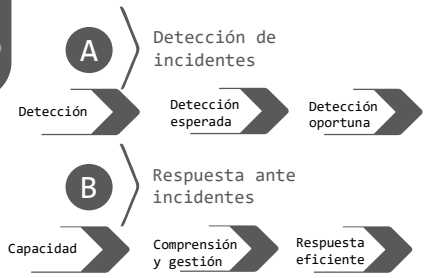
Prácticas de Seguridad

Operaciones

Gestión de Incidents (IM)

Se enfoca en detectar y responder de manera estructurada ante brechas de seguridad o amenazas inminentes en aplicaciones en producción.

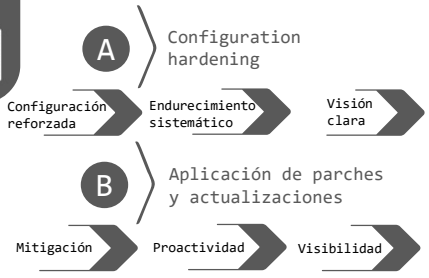
- Se centra en reducir el tiempo entre la brecha y su identificación para mitigar el daño acumulado y su recuperación.
- Establece un proceso coordinado para contener el impacto de los ataques y restablecer las operaciones normales.



Gestión del Entorno (EM)

Se centra en mantener la infraestructura y el stack durante toda la etapa operativa del software.

- Aplica de manera consistente configuraciones de seguridad en todos los componentes.
- Monitorea continuamente los reportes de fallas de seguridad para aplicar actualizaciones y parches .
- Administra y actualiza la tecnología del sistema a lo largo de su vida útil.



Gestión Operativa (OM)

Garantiza la seguridad en todas las funciones de soporte operativo para evitar que fallas en la infraestructura invaliden las protecciones integradas en la aplicación.

- Evita que el uso de sistemas sin soporte, vulnerabilidades no parcheadas o respaldos inseguros anulen las medidas de seguridad del software.
- Gestión de infraestructura.
- Resguardo de datos.

